

AICS-112 SavannaPay SOAR Build: Test and Metrics Report

Student: Mohammed, 2026AICDF16701. Final run: **18 tests, OK** (evidence/lab7_tests.txt), repeated on a fresh extracted copy of the submission ZIP. All tests run with dry_run true and no live actions.

1. Test record (Template E)

Test ID	Requirement	Input / precondition	Expected	Actual	Pass ?	Evidence
T-01	Timezone handling (negative test)	Event with a naive timestamp (no timezone)	Rejected, not guessed	Rejected (test_naive_timestamp_rejected)	Yes	evidence/lab7_tests.txt
T-02	Schema normalisation	Raw event with mixed timestamp and field formats	Timestamp and fields normalised to the schema	Normalised (test_normalize_timestamp_and_fields)	Yes	evidence/lab7_tests.txt
T-03	Controlled false joins on IOC's (negative tests)	IOC that is low-confidence, expired, or not yet valid (before valid_from)	Not treated as a match	No match in all three cases (low_confidence, expired, before_valid_from tests)	Yes	evidence/lab7_tests.txt; lab6_tests.txt
T-04	Explainable scoring and severity boundaries	Scored incidents at and around severity cut-offs	Score has stated reasons; boundaries map to correct severity	As expected (test_score_is_explainable, test_severity_boundaries)	Yes	evidence/lab7_tests.txt; lab4_threshold_experiment.txt
T-05	Prompt-injection defence (negative test)	Hostile text inside evidence trying to approve actions	Flagged; approval status unchanged	Flagged, no approval change (test_prompt_injection_flag, test_adversarial_prompt_injection_cannot_approve_actions)	Yes	evidence/lab7_tests.txt; lab4_injection.txt
T-06	Approval gate on high-impact actions (negative test)	Critical plan with no named approval	Plan requires approval and stays awaiting	Stays awaiting (test_critical_plan_requires_approval, test_critical_without_approval_stays_awaiting)	Yes	evidence/lab7_tests.txt; lab5_planned_actions.txt
T-07	Idempotency	Same action replayed	No duplicate execution	Replay handled (test_idempotency_replay)	Yes	evidence/lab7_tests.txt; lab5_idempotency.txt
T-08	Tamper-evident audit log	Hash-chained audit log, then verify_audit.py	Tampering detectable; untouched log verifies	test_hash_chain_detectable passes; verify_audit.py reports "chain OK"	Yes	evidence/lab7_tests.txt; lab7_audit_chain.txt

2. Other unit tests in the final run

Test	Type	Purpose	Result
test_enrichment_adds_context_and_ioc	Positive	Enrichment adds context and IOC data	ok
test_approved_change_is_not_a_malware_signal	Negative	An approved change is not flagged as malware	ok
test_unapproved_encoded_powershell_is_a_malware_signal	Positive	Unapproved encoded PowerShell is flagged	ok
test_identity_only_incident_does_not_plan_isolation	Negative	Identity-only incident does not plan host isolation	ok
test_oauth_consent_plans_gated_revoke	Positive	OAuth consent incident plans a gated revoke	ok

Progress note: the Lab 6 run (12 tests) recorded the expired-IOC test as an expected failure. In the final Lab 7 run (18 tests) it passes.

3. Precision and recall

TP	FP	TN	FN	Precision	Recall	F1
8	0	4	0	1.0	1.0	1.0

The same figures appear in evidence/metrics.txt, lab6_metrics.txt and lab7_regression_metrics.txt, so the Lab 7 changes caused no regression. The set is small (12 labelled cases), so perfect scores are not proof of general performance.

Threshold experiment

Threshold	TP	FP	FN	Precision	Recall
30	8	1	0	0.89	1.00
40	8	1	0	0.89	1.00
50	8	0	0	1.00	1.00
65	8	0	0	1.00	1.00
75	8	0	0	1.00	1.00
85	8	0	0	1.00	1.00

Recommendation: escalate at 65, notify-only at 40. Containment still needs named human approval. Thresholds 30 and 40 add one false positive (SOAR-0005, score 44), which costs analyst time. Going above 85 risks missing a real attack, which costs more. Limitation: the training data has one attack chain, so equal results across 50 to 85 are weak evidence. The threshold should be re-checked on the blind capstone data.

4. Latency assumptions

Measured: the full 18-test suite runs in about 0.007 s (0.005 to 0.007 s across the saved runs), so the deterministic pipeline steps (normalise, enrich, score, plan, audit) add negligible delay on this dataset.

Assumptions (not benchmarked):

- Processing is batch and local, over a small dataset of 12 labelled cases. Timings will not scale linearly to production alert volumes.
- The AI-assisted analysis step (Ollama, qwen3:4b, local) is the slowest automated step. One measured run of the SOAR-0001 analysis took **2 min 27.7 s** end to end (time curl against /api/ai/analyze, single run on the student's laptop, so it is indicative, not a benchmark, and may include model load time). In earlier console runs the call timed out and the pipeline used the offline fallback (evidence/lab4_ai_analysis_offline.json), which returns immediately. The timeout is configurable (AICS112_OLLAMA_TIMEOUT), so a slow model delays advice but never blocks detection, scoring or the approval gate.
- End-to-end response time is dominated by the human approval gate for high-impact actions, not by machine processing. Notify-only actions do not wait for approval.
- All actions are dry-run, so no external system latency (firewall, identity provider) is included.

5. Integrity check

python3 verify_audit.py evidence/capstone/audit_log_with_approvals.jsonl returned **chain OK** on a fresh copy of the submission ZIP.